RAPPORT DE PROJET FINAL

Mise en place d'un serveur de fichiers Samba en PME

Auteur1 : KPODONOU Kossigan Gael God-Love

Auteur2 : GNIGMA Bruno

Professeur : Dr. DJEKI

Matiere : Generalites sur les Stockages de l'information (INF 1527)

Annee scolaire : 2025–2026

Contents

1 Introduction et objectifs **3**

2 Recherche theorique **3**
2.1 Qu'est-ce que Samba ? . . . 3
2.2 Le protocole SMB et ses versions . . . 3
2.3 Bonnes pratiques de securisation Samba . . . 4
2.4 Permissions Linux et Samba . . . 4

3 Architecture et environnement **5**
3.1 Topologie du laboratoire . . . 5
3.2 Choix de la configuration reseau . . . 5
3.2.1 Configuration reseau du serveur (netplan) . . . 6
3.3 Organisation des services et utilisateurs . . . 6

4 Installation et configuration **6**
4.1 Installation de Samba . . . 6
4.2 Creation de la structure des dossiers . . . 7
4.3 Creation des groupes et utilisateurs . . . 7
4.3.1 Creation des groupes Linux . . . 7
4.3.2 Creation des utilisateurs Linux et Samba . . . 8
4.4 Application des permissions sur les dossiers . . . 9
4.5 Configuration du fichier smb.conf . . . 10
4.5.1 Validation de la configuration . . . 12

5 Tests de validation des acces **14**
5.1 Test de connexion reussie – partage `direction` . . . 14
5.2 Test de refus d'acces – isolation des partages . . . 15
5.3 Test du partage commun – acces multi-groupes . . . 15

6 Journalisation **16**
6.1 Configuration et verification . . . 17
6.2 Contenu des logs – tracabilite des connexions . . . 17

7 Securite – Protection contre les attaques **18**
7.1 Desactivation de SMBv1 . . . 18
7.2 Attaque 1 – Enumeration anonyme . . . 19
7.2.1 Demonstration de la vulnerabilite (avant correction) . . . 19
7.2.2 Correction – restriction de l'acces anonyme . . . 19
7.2.3 Validation de la correction . . . 20
7.3 Attaque 2 – Brute force par dictionnaire (Hydra / CrackMapExec) . . . 20
7.3.1 Tentative avec Hydra . . . 20
7.3.2 Attaque avec CrackMapExec (SMB2/NTLMv2) . . . 21
7.4 Fail2ban – blocage automatique des attaquants . . . 22
7.4.1 Installation et configuration . . . 22
7.4.2 Validation – bannissement automatique en action . . . 25

8 Sauvegarde automatisee **26**
8.1 Strategie de sauvegarde 26
8.2 Script de sauvegarde 27
8.3 Automatisation via cron 28
8.4 Test de restauration 29
8.4.1 Probleme identifie : pourquoi `sudo cp` est insuffisant 29
8.4.2 Etape 4 – Restauration correcte avec `rsync -archive` 31

9 Difficultes rencontrees et choix techniques **32**
9.1 Difficultes rencontrees 32
9.1.1 Configuration reseau de la VM 32
9.1.2 Instabilite de l'IP de Kali 33
9.1.3 Configuration de Fail2ban 33
9.1.4 Conflit d'IP avec le reseau Host-Only 33
9.2 Choix techniques justifies 34

10 Perspectives d'amelioration **34**

11 Conclusion **35**

A Annexe – Recapitulatif des commandes utilisees **36**

1 Introduction et objectifs

Dans un contexte ou la gestion centralisee des donnees est devenue indispensable pour toute organisation, les PME font face a des defis croissants en matiere de partage de fichiers, de controle d'acces et de securite informatique. Ce projet a pour objet la conception et le deploiement d'un serveur de fichiers **Samba** pour une PME fictive comptant quatre services : Direction, Comptabilite, Ressources Humaines et Technique.

Objectifs

- Centraliser les donnees de l'entreprise sur un serveur Linux sous Ubuntu Server ;
- Creer des espaces de stockage dedies par service avec des droits d'acces stricts ;
- Securiser les communications en desactivant SMBv1 et en imposant SMB2/SMB3 ;
- Proteger le serveur contre les attaques courantes (brute force, enumeration anonyme) ;
- Mettre en place une strategie de sauvegarde automatisee avec procedure de restauration testee ;
- Documenter l'integralite de la demarche dans ce rapport.

2 Recherche theorique

2.1 Qu'est-ce que Samba ?

Samba est une implementation libre et open-source du protocole **SMB/CIFS** (*Server Message Block / Common Internet File System*) pour les systemes Unix/Linux. Il permet a des machines Linux de partager des fichiers, des imprimantes et d'autres ressources avec des clients Windows, macOS ou Linux sur un reseau local. Developpe initialement par Andrew Tridgell en 1992 par retro-ingenierie du protocole SMB, Samba est aujourd'hui maintenu par une large communaute open-source et constitue la solution de reference pour l'interoperabilite Linux/Windows en entreprise.

Samba est compose de plusieurs demons :

- `smbd` : gere les partages de fichiers, l'authentification des utilisateurs et les impressions reseau. C'est le demon principal que l'on interagit au quotidien ;
- `nmbd` : gere la resolution de noms NetBIOS, permettant aux machines de se trouver par nom sur le reseau local ;
- `winbindd` : permet l'integration a un domaine Active Directory/LDAP, utile pour les grands reseaux d'entreprise.

2.2 Le protocole SMB et ses versions

Le protocole **SMB (Server Message Block)** est un protocole de couche application permettant le partage de ressources (fichiers, imprimantes, ports serie) entre machines d'un reseau local. Initialement concu par IBM et adopte par Microsoft, il a evolue de maniere significative au fil des annees.

Dans l'ancien Windows NT 4, il etait appele **CIFS (Common Internet File System)**. La version 2 de SMB est apparue dans Vista, Windows 7 et Windows 8. Actuellement SMB est en version **3.1.1**, introduite dans Windows 10 et Windows Server 2016.

Version	Systemes concernes	Statut de securite
SMBv1	Windows XP, Server 2003	**Obsolete – a desactiver**
SMBv2	Windows Vista, Server 2008	Acceptable
SMBv3	Windows 8, Server 2012+	**Recommande**

Table 1: Versions du protocole SMB

Danger SMBv1 – Vulnerabilite critique

SMBv1 est le protocole a l'origine des attaques *WannaCry* (mai 2017) et *NotPetya* (juin 2017), qui ont cause des milliards de dollars de dommages dans le monde entier, infectant des hopitaux, des banques et des grandes entreprises. Sa desactivation est une **exigence absolue de securite** dans tout environnement professionnel.

2.3 Bonnes pratiques de securisation Samba

1. **Desactiver SMBv1** : utiliser `min protocol = SMB2` dans la configuration globale pour forcer l'utilisation de protocoles modernes.
2. **Authentification par utilisateur** : `security = user` impose un login/mot de passe pour chaque connexion. C'est le mode oppose au mode "share" (acces sans authentification) qui est depasse.
3. **Mots de passe robustes** : chaque utilisateur doit avoir un mot de passe fort (majuscule, chiffre, caractere special, longueur $\geq$ 10 caracteres) pour resister aux attaques par dictionnaire comme celle avec `rockyou.txt`.
4. **Principe du moindre privilege** : chaque groupe accede *uniquement* a son dossier dedie. Un employe de la comptabilite ne doit pas pouvoir lire les fichiers RH.
5. **Interdire la navigation anonyme** : `restrict anonymous = 2` empeche un attaquant de lister les partages sans s'authentifier (enumeration).
6. **Journalisation** : activer les logs (niveau 2) pour tracer toutes les connexions et tentatives d'acces. Indispensable en cas d'incident.
7. **Protection contre le brute force** : deployer `fail2ban` pour bannir automatiquement les IP suspectes apres un nombre d'echecs configurable.
8. **Sauvegarde reguliere** : mettre en place des sauvegardes completes et incrementielles automatisees, avec tests de restauration reguliers.

2.4 Permissions Linux et Samba

La securite d'un partage Samba repose sur **deux couches de permissions** qui s'appliquent simultanement et de maniere independante :

- **Permissions Linux (POSIX)** : definies via `chmod` et `chown`. Ce sont les permissions du systeme de fichiers sous-jacent, appliquees par le noyau Linux independamment de Samba.
- **Permissions Samba** : definies dans `smb.conf` via `valid users`, `read only`, `create mask`, etc.

Regle des permissions effectives

La permission effective est le **plus restrictif** des deux niveaux. Un utilisateur qui a acces via Samba (`valid users`) mais dont le compte Linux n'a pas les droits sur le dossier se verra quand meme refuse. Il est donc indispensable de configurer correctement *les deux* niveaux.

3 Architecture et environnement

3.1 Topologie du laboratoire

L'environnement de test a ete mis en place sur VirtualBox installe sur un hote physique fonctionnant sous Ubuntu Desktop. Trois machines constituent l'infrastructure :

Role	Systeme	IP	Interface
Serveur Samba	Ubuntu Server 24.04	192.168.1.118 (Bridge)	enp0s3
		192.168.56.20 (Host-Only)	enp0s8
Client Linux	Ubuntu Desktop (hote)	192.168.56.1	vboxnet0
Attaquant	Kali Linux 2025.4	192.168.56.40	eth1

Table 2: Inventaire des machines du laboratoire

3.2 Choix de la configuration reseau

Deux cartes reseau ont ete configurees sur la VM serveur :

- **Carte 1 (Bridge – enp0s3)** : place la VM sur le meme reseau physique que la machine hote. Permet l'acces a Internet pour l'installation des paquets (`apt install`). Elle recoit son IP via DHCP depuis la box domestique.
- **Carte 2 (Host-Only – enp0s8)** : cree un reseau prive `192.168.56.0/24` entre la VM, l'hote et Kali. C'est sur cette interface que transitent les connexions Samba et les tests de securite.

Pourquoi Host-Only pour les tests Samba ?

Le reseau Host-Only isole le trafic de test du reseau physique, ce qui est une bonne pratique en laboratoire. Cela evite d'exposer le serveur (potentiellement non completement securise en phase de test) aux autres machines du reseau reel, et empeche tout risque de perturbation du reseau domestique par les attaques generees depuis Kali.

3.2.1 Configuration reseau du serveur (netplan)

Ubuntu Server utilise **netplan** pour gerer les interfaces reseau. La configuration est declarative (format YAML) et remplace les anciens fichiers `/etc/network/interfaces`.

Listing 1: /etc/netplan/00-installer-config.yaml

```
network:
  version: 2
  ethernets:
    enp0s3:
      dhcp4: true        # IP automatique via DHCP (acces
         internet)
    enp0s8:
      dhcp4: no          # Pas de DHCP : IP statique
      addresses:
        - 192.168.56.20/24  # IP fixe sur le reseau Host-Only
```

Apres toute modification du fichier YAML, la commande `sudo netplan apply` recharge la configuration reseau sans redemarrer la machine. Si l'interface reste en etat `NO-CARRIER`, verifier que la case *Cable connecte* est cochee dans les parametres VirtualBox de l'adaptateur reseau.

3.3 Organisation des services et utilisateurs

Le projet impose la creation d'au moins 8 utilisateurs repartis en 4 groupes correspondant aux services de la PME.

Groupe Linux	Utilisateurs	Dossier partage
`direction`	direction1, direction2	`/srv/samba/direction`
`comptabilite`	compta1, compta2	`/srv/samba/comptabilite`
`rh`	rh1, rh2	`/srv/samba/rh`
`technique`	tech1, tech2	`/srv/samba/technique`
(tous)	tous les groupes	`/srv/samba/commun`

Table 3: Organisation des groupes, utilisateurs et partages

4 Installation et configuration

4.1 Installation de Samba

Apres mise a jour du systeme, Samba est installe via le gestionnaire de paquets :

```
sudo apt update && sudo apt install samba -y
samba --version
sudo systemctl status smbd
```

```
Version 4.19.5-Ubuntu
vboxuser@ubuntu:~$ sudo systemctl status smbd
● smbd.service - Samba SMB Daemon
     Loaded: loaded (/usr/lib/systemd/system/smbd.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-02-26 22:34:34 UTC; 1min 49s ago
       Docs: man:smbd(8)
             man:samba(7)
             man:smb.conf(5)
   Main PID: 2189 (smbd)
     Status: "smbd: ready to serve connections..."
      Tasks: 3 (limit: 1057)
     Memory: 9.1M (peak: 9.3M)
        CPU: 165ms
     CGroup: /system.slice/smbd.service
             ├─2189 /usr/sbin/smbd --foreground --no-process-group
             ├─2192 "smbd: notifyd" .
             └─2193 "smbd: cleanupd "

Feb 26 22:34:29 ubuntu systemd[1]: Starting smbd.service - Samba SMB Daemon...
Feb 26 22:34:30 ubuntu (smbd)[2189]: smbd.service: Referenced but unset environment variable evaluates to an empty string: SMBDOPTIONS
Feb 26 22:34:34 ubuntu systemd[1]: Started smbd.service - Samba SMB Daemon.
vboxuser@ubuntu:~$
```

Figure 1: Samba 4.19.5 installe et service `smbd` actif – statut `active (running)`

- `sudo` : execute la commande avec les privileges administrateur (root).
- `apt update` : met a jour la liste des paquets disponibles depuis les depots officiels. Ne met PAS a jour les paquets installes – seulement la liste.
- `&&` : enchaine la commande suivante *uniquement* si la precedente a reussi (code de retour 0).
- `apt install samba -y` : installe le paquet `samba` et ses dependances. Le `-y` repond automatiquement "oui" aux questions de confirmation.

4.2 Creation de la structure des dossiers

```
sudo mkdir -p /srv/samba/direction
sudo mkdir -p /srv/samba/comptabilite
sudo mkdir -p /srv/samba/rh
sudo mkdir -p /srv/samba/technique
sudo mkdir -p /srv/samba/commun
```

- `mkdir` : cree un repertoire (*make directory*).
- `-p` : cree les repertoires parents manquants sans erreur. Ici, si `/srv/samba/` n'existe pas encore, il sera cree automatiquement avant `direction/`. Sans `-p`, la commande echouerait si le parent n'existe pas.
- `/srv/samba/` : chemin standardise FHS (Filesystem Hierarchy Standard) pour les donnees de services. `/srv` est prevu pour les donnees servies par le systeme.

4.3 Creation des groupes et utilisateurs

4.3.1 Creation des groupes Linux

```
sudo groupadd direction
sudo groupadd comptabilite
sudo groupadd rh
sudo groupadd technique
```

- `groupadd` : cree un nouveau groupe dans le fichier `/etc/group`.
- Chaque groupe se voit attribuer un **GID** (Group IDentifier) unique, automatiquement incremente a partir de 1000 pour les groupes systeme non-root.
- Les groupes Linux sont le mecanisme fondamental de controle d'acces. Un fichier appartenant au groupe `direction` n'est accessible qu'aux membres de ce groupe (si les permissions le definissent ainsi).
- Verification : `cat /etc/group | grep direction` pour voir le GID attribue.

4.3.2 Creation des utilisateurs Linux et Samba

Chaque utilisateur est cree avec son groupe principal, un mot de passe Linux (`passwd`), puis enregistre dans la base Samba (`smbpasswd`) :

```
sudo useradd -m -G direction direction1
sudo useradd -m -G direction direction2
sudo useradd -m -G comptabilite compta1
sudo useradd -m -G comptabilite compta2
sudo useradd -m -G rh rh1
sudo useradd -m -G rh rh2
sudo useradd -m -G technique tech1
sudo useradd -m -G technique tech2

# Mot de passe Linux (exemple pour direction1)
sudo passwd direction1   # ex: Direction1/+2026

# Enregistrement dans la base Samba
sudo smbpasswd -a direction1
# Repeter pour chaque utilisateur
```

- `useradd` : cree un nouvel utilisateur dans `/etc/passwd` et `/etc/shadow`.
- `-m` : cree le repertoire personnel `/home/direction1/` de l'utilisateur. Sans `-m`, aucun home n'est cree, ce qui peut causer des problemes de connexion.
- `-G direction` : ajoute l'utilisateur au groupe supplementaire `direction`. Distinction importante : le groupe *principal* (defini par `-g`) est celui par defaut

lors de la creation de fichiers ; les groupes *supplementaires* (definis par `-G`) donnent des droits d'acces additionnels.

- `sudo passwd direction1` : definit le mot de passe du compte Linux. Ce mot de passe est stocke (hache) dans `/etc/shadow`.

Deux bases de mots de passe independantes

Samba maintient sa **propre base de mots de passe** dans `/var/lib/samba/private/passdb.tdb`, totalement independante du systeme Linux (`/etc/shadow`). La commande `smbpasswd -a <user>` enregistre l'utilisateur dans cette base Samba. Un utilisateur peut avoir un mot de passe Linux different de son mot de passe Samba. Pour simplifier l'administration en laboratoire, les memes mots de passe ont ete utilises dans les deux bases.

4.4 Application des permissions sur les dossiers

```
# Etape 1 : Changer le proprietaire (groupe) de chaque dossier
sudo chown root:direction    /srv/samba/direction
sudo chown root:comptabilite /srv/samba/comptabilite
sudo chown root:rh           /srv/samba/rh
sudo chown root:technique    /srv/samba/technique
sudo chown root:root         /srv/samba/commun

# Etape 2 : Appliquer les permissions
sudo chmod 2770 /srv/samba/direction
sudo chmod 2770 /srv/samba/comptabilite
sudo chmod 2770 /srv/samba/rh
sudo chmod 2770 /srv/samba/technique
sudo chmod 2777 /srv/samba/commun
```

- `chown` : change le proprietaire (*change owner*) d'un fichier ou repertoire.
- Syntaxe : `chown <utilisateur>:<groupe> <cible>`
- `root:direction` : le proprietaire est `root` (seul l'admin peut modifier les permissions globales), et le groupe proprietaire est `direction` (les membres de ce groupe auront les droits definis pour le groupe).
- Cela signifie : *ce dossier appartient a root mais est administre par le groupe direction.*

Les permissions Linux s'expriment en octal sur 4 chiffres :

Bit special	Proprietaire	Groupe	Autres
2 (setgid)	7 (rwx)	7 (rwx)	0 (—)

- **Valeur 7 = rwx** : r (read=4) + w (write=2) + x (execute=1) = 7. Acces complet : lecture, ecriture, navigation.
- **Valeur 0 = —** : aucun droit. Les *autres* (utilisateurs hors proprietaire et hors groupe) ne peuvent rien faire.
- **Bit setgid (2 en tete)** : quand un utilisateur cree un fichier dans ce dossier, le fichier herite automatiquement du **groupe du dossier** (ex. `direction`) et non du groupe principal de l'utilisateur. Cela garantit que tous les fichiers crees restent accessibles a tout le groupe.
- **chmod 2777** (dossier commun) : tout le monde (proprietaire, groupe, autres) a tous les droits. Avec le setgid, les nouveaux fichiers appartiennent au groupe du dossier. Cela permet a tous les employes (tous groupes confondus) de partager des fichiers dans l'espace commun.
- **Resume visuel** :
  - `2770` → `drwxrws--` : acces total groupe, zero pour les autres
  - `2777` → `drwxrwsrwx` : acces total pour tous + setgid

```
vboxuser@ubuntu:~$
vboxuser@ubuntu:~$
vboxuser@ubuntu:~$
vboxuser@ubuntu:~$ ls -la /srv/samba
total 28
drwxr-xr-x 7 root root         4096 Feb 26 22:55 .
drwxr-xr-x 3 root root         4096 Feb 26 22:40 ..
drwxrwsrwx 2 root root         4096 Feb 26 22:55 commun
drwxrws--- 2 root comptabilite 4096 Feb 26 22:54 comptabilite
drwxrws--- 2 root direction    4096 Feb 26 22:40 direction
drwxrws--- 2 root rh           4096 Feb 26 22:54 rh
drwxrws--- 2 root technique    4096 Feb 26 22:55 technique
vboxuser@ubuntu:~$ _
```

Figure 2: Structure `/srv/samba/` – permissions correctement appliquees. On distingue clairement les groupes proprietaires (`direction`, `comptabilite`, `rh`, `technique`) et les permissions `drwxrws--` (2770) et `drwxrwsrwx` (2777) pour `commun`.

4.5 Configuration du fichier smb.conf

Le fichier de configuration principal est sauvegarde avant modification (bonne pratique indispensable) :

```
sudo cp /etc/samba/smb.conf /etc/samba/smb.conf.bak
sudo nano /etc/samba/smb.conf
```

Listing 2: /etc/samba/smb.conf – configuration complete

```
[global]
   workgroup = WORKGROUP
   server string = Serveur Samba PME
   server role = standalone server

   # === SECURITE ===
   security = user          # Authentification par compte
      utilisateur
   min protocol = SMB2      # Interdit SMBv1 (WannaCry, NotPetya)
   max protocol = SMB3      # Limite au protocole moderne

   # Interdit la navigation anonyme (enumeration des partages)
   restrict anonymous = 2

   # === LOGS ===
   log file = /var/log/samba/log.%m  # Un fichier par machine
      cliente
   max log size = 1000               # Taille max en Ko
   logging = file
   log level = 2                     # Niveau detaille (0=minimal
      , 10=max)

[direction]
   path = /srv/samba/direction
   valid users = @direction   # @ = groupe Linux
   read only = no             # Ecriture autorisee
   browseable = yes
   create mask = 0660         # Nouveaux fichiers : rw-rw----
   directory mask = 2770      # Nouveaux dossiers : rwxrws---

[comptabilite]
   path = /srv/samba/comptabilite
   valid users = @comptabilite
   read only = no
   browseable = yes
   create mask = 0660
   directory mask = 2770

[rh]
   path = /srv/samba/rh
   valid users = @rh
   read only = no
   browseable = yes
   create mask = 0660
   directory mask = 2770

[technique]
   path = /srv/samba/technique
   valid users = @technique
   read only = no
```

```
   browseable = yes
   create mask = 0660
   directory mask = 2770

[commun]
   path = /srv/samba/commun
   valid users = @direction @comptabilite @rh @technique
   read only = no
   browseable = yes
   create mask = 0666   # Fichiers lisibles/modifiables par tous
   directory mask = 2777
```

- `security = user` : chaque connexion doit s'authentifier avec un nom d'utilisateur et un mot de passe Samba. Mode oppose : `security = share` (acces sans mot de passe, depasse et dangereux).
- `min protocol = SMB2` : force l'utilisation de SMB version 2 minimum. Toute tentative de connexion en SMBv1 est rejetee.
- `restrict anonymous = 2` : niveau maximum de restriction anonyme. Valeur 0 = pas de restriction, valeur 1 = restriction partielle, valeur 2 = aucun acces anonyme du tout (enumeration impossible).
- `valid users = @direction` : le `@` indique un groupe Linux. Seuls les membres du groupe `direction` peuvent acceder a ce partage. Sans `@`, ce serait un utilisateur individuel.
- `create mask = 0660` : masque de permissions pour les nouveaux fichiers. `0660` = rw-rw—- (proprietaire et groupe peuvent lire/ecrire, les autres n'ont rien). Equivalent de `chmod 660` sur chaque nouveau fichier.
- `log. %m` : `%m` est une variable Samba remplacee par le nom NetBIOS ou l'adresse IP du client. Cela cree un fichier de log par machine connectee, facilitant les investigations.

4.5.1 Validation de la configuration

```
testparm                # Verifie smb.conf sans redemarrer Samba
sudo systemctl restart smbd  # Prend en compte les modifications
```

```
vboxuser@ubuntu:~$ testparm
Load smb config files from /etc/samba/smb.conf
Loaded services file OK.
Weak crypto is allowed by GnuTLS (e.g. NTLM as a compatibility fallbac

Server role: ROLE_STANDALONE

Press enter to see a dump of your service definitions
_
```

Figure 3: `testparm` – configuration valide. Le message `Loaded services file OK` confirme l'absence d'erreur de syntaxe. L'avertissement `Weak crypto is allowed by GnuTLS` est informatif (compatibilite NTLMv2) et n'est pas bloquant.

```
[direction]
        create mask = 0660
        directory mask = 02770
        path = /srv/samba/direction
        read only = No
        valid users = @direction


[comptabilite]
        create mask = 0660
        directory mask = 02770
        path = /srv/samba/comptabilite
        read only = No
        valid users = @comptabilite


[rh]
        create mask = 0660
        directory mask = 02770
        path = /srv/samba/rh
        read only = No
        valid users = @rh


[technique]
        create mask = 0660
        directory mask = 02770
        path = /srv/samba/technique
        read only = No
        valid users = @technique


[commun]
        create mask = 0666
        directory mask = 02777
        path = /srv/samba/commun
        read only = No
        valid users = @direction @comptabilite @rh @technique
```

Figure 4: Resultat de `testparm` affichant le dump complet de la configuration – on reconnait les sections `[direction]`, `[comptabilite]`, `[rh]`, `[technique]`, `[commun]` avec leurs parametres. Service `smbd` ensuite redemarre avec succes.

5 Tests de validation des acces

5.1 Test de connexion reussie – partage `direction`

Depuis le PC hote (client Linux), on utilise `smbclient` pour se connecter :

```
smbclient //192.168.56.20/direction -U direction1
```

```
adrien@adrien-RC530-RC730:~$ smbclient -L //192.168.56.20 -U direction1
Password for [WORKGROUP\direction1]:

        Sharename       Type      Comment
        ---------       ----      -------
tstream_smbXcli_np_destructor: cli_close failed on pipe srvsvc. Error was NT_STA
TUS_IO_TIMEOUT
cli_rpc_pipe_open_noauth: rpc_pipe_bind for pipe srvsvc failed with error NT_STA
TUS_IO_TIMEOUT
SMB1 disabled -- no workgroup available
adrien@adrien-RC530-RC730:~$
```

Figure 5: Premiere tentative avec SMB1 – message `SMB1 disabled - no workgroup available` confirme que le serveur rejette correctement les connexions SMBv1. C'est le comportement attendu de notre configuration `min protocol = SMB2`.

```
adrien@adrien-RC530-RC730:~$ smbclient //192.168.56.20/direction -U direction1
Password for [WORKGROUP\direction1]:
Try "help" to get a list of possible commands.
smb: \> mkdir test_direction
smb: \> ls
  .                                   D        0  Fri Feb 27 06:02:14 2026
  ..                                  D        0  Fri Feb 27 06:02:14 2026
  test_direction                      D        0  Fri Feb 27 06:02:14 2026

                30784420 blocks of size 1024. 24856592 blocks available
smb: \> exit
adrien@adrien-RC530-RC730:~$ smbclient //192.168.56.20/rh -U direction1
Password for [WORKGROUP\direction1]:
tree connect failed: NT_STATUS_ACCESS_DENIED
adrien@adrien-RC530-RC730:~$
```

Figure 6: Connexion SMB2 reussie par `direction1` : creation du dossier `test_direction` visible via `ls`, suivi du test d'isolation (`smbclient .../rh`) qui retourne `NT_STATUS_ACCESS_DENIED`. Les deux tests sont visibles dans la meme capture.

5.2 Test de refus d'acces – isolation des partages

On tente d'acceder au partage `rh` avec l'utilisateur `direction1` qui n'appartient pas au groupe `rh` :

```
smbclient //192.168.56.20/rh -U direction1
```

Resultat attendu – isolation confirmee

`tree connect failed: NT_STATUS_ACCESS_DENIED`

L'acces est bien refuse. Les partages sont correctement isoles entre les groupes. Ce resultat est visible dans la figure 6 ci-dessus (derniere ligne de la capture).

5.3 Test du partage commun – acces multi-groupes

Etape 1 : `direction1` depose un fichier dans le partage commun :

```
# Creation du fichier sur la machine hote
echo "Fichier de test PME" > /tmp/fichier_test.txt

# Connexion au partage commun et upload
smbclient //192.168.56.20/commun -U direction1
smb: \> put /tmp/fichier_test.txt fichier_test.txt
smb: \> ls
```

```
smb: \> put /tmp/fichier_test.txt fichier_test.txt
putting file /tmp/fichier_test.txt as \fichier_test.txt (0.6 kb/s) (average 0.6 kb/s)
smb: \> ls
  .                                   D        0  Fri Feb 27 06:53:21 2026
  ..                                  D        0  Fri Feb 27 06:53:21 2026
  fichier_test.txt                    A       20  Fri Feb 27 06:53:21 2026

                30784420 blocks of size 1024. 24856492 blocks available
smb: \>
```

Figure 7: Upload du fichier `fichier_test.txt` dans `/commun` par `direction1`. Le listing `ls` confirme sa presence (taille 20 octets, date de creation visible).

Etape 2 : `compta1` (groupe different) peut lire et telecharger ce fichier :

```
adrien@adrien-RC530-RC730:~$ smbclient //192.168.56.20/commun -U compta1
Password for [WORKGROUP\compta1]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Fri Feb 27 06:53:21 2026
  ..                                  D        0  Fri Feb 27 06:53:21 2026
  fichier_test.txt                    A       20  Fri Feb 27 06:53:21 2026

                30784420 blocks of size 1024. 24856488 blocks available
smb: \> get fichier_test.txt
getting file \fichier_test.txt of size 20 as fichier_test.txt (2.8 KiloBytes/sec) (average 2.8 KiloBytes/sec)
smb: \>
```

Figure 8: `compta1` se connecte a `/commun`, liste les fichiers et telecharge `fichier_test.txt` via `get`. Le fichier depose par un membre d'un groupe different est bien accessible. Le partage commun est fonctionnel.

Utilisateur	/direction	/comptabilite	/rh	/technique	/commun
direction1	Oui	Non	Non	Non	Oui
compta1	Non	Oui	Non	Non	Oui
rh1	Non	Non	Oui	Non	Oui
tech1	Non	Non	Non	Oui	Oui

Table 4: Matrice des acces – Oui = autorise, Non = refuse (NT_STATUS_ACCESS_DENIED)

6 Journalisation

6.1 Configuration et verification

La journalisation est activee dans `smb.conf` avec le niveau 2, ce qui enregistre les authentifications, les connexions et les acces aux partages. Les logs sont generes dans `/var/log/samba/` avec un fichier par machine cliente (`log.%m`).

```
vboxuser@ubuntu:~$ sudo ls /var/log/samba/
[sudo] password for vboxuser:
Sorry, try again.
[sudo] password for vboxuser:
cores               log.adrien-rc530-rc730  log.rpcd_fsrvp    log.rpcd_winreg
log.                log.nmbd                log.rpcd_lsad     log.samba-dcerpcd
log.192.168.1.124   log.rpcd_classic        log.rpcd_mdssvc   log.smbd
log.192.168.56.1    log.rpcd_epmapper       log.rpcd_spoolss
vboxuser@ubuntu:~$
```

```
vboxuser@ubuntu:~$ sudo ls -la /var/log/samba/
total 28
drwxr-x---  3 root adm    4096 Feb 27 05:57 .
drwxrwxr-x 12 root syslog 4096 Feb 27 00:00 ..
drwx------  7 root root   4096 Feb 27 05:57 cores
-rw-r--r--  1 root root    746 Feb 27 05:58 log.
-rw-r--r--  1 root root      0 Feb 27 03:14 log.192.168.1.124
-rw-r--r--  1 root root   1488 Feb 27 06:15 log.192.168.56.1
-rw-r--r--  1 root root      0 Feb 27 05:57 log.adrien-rc530-rc730
-rw-r--r--  1 root root    446 Feb 27 05:47 log.nmbd
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_classic
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_epmapper
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_fsrvp
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_lsad
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_mdssvc
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_spoolss
-rw-r--r--  1 root root      0 Feb 27 05:57 log.rpcd_winreg
-rw-r--r--  1 root root      0 Feb 27 05:57 log.samba-dcerpcd
-rw-r--r--  1 root root   3756 Feb 27 06:15 log.smbd
```

Figure 9: Contenu de `/var/log/samba/` apres les tests : on distingue un fichier par machine ayant communique avec le serveur (`log.192.168.56.1` pour le client hote, `log.192.168.56.30` et `log.192.168.56.40` pour les attaquants Kali). Le fichier `log.adrien-rc530-rc730` correspond au nom NetBIOS de la machine hote resolue par Samba.

6.2 Contenu des logs – tracabilite des connexions

Le fichier `log.192.168.56.1` (machine hote) contient les traces d'authentification :

```
vboxuser@ubuntu:~$ sudo cat /var/log/samba/log.192.168.56.1
[2026/02/27 06:14:42.020272,  2] source3/auth/auth.c:332(auth_check_ntlm_password)
  check_ntlm_password:  authentication for user [direction1] -> [direction1] -> [direction1] succeeded
[2026/02/27 06:14:42.020776,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[direction]"
[2026/02/27 06:14:42.020894,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[comptabilite]"
[2026/02/27 06:14:42.020978,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[rh]"
[2026/02/27 06:14:42.021058,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[technique]"
[2026/02/27 06:14:42.021154,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[commun]"
[2026/02/27 06:15:58.902091,  2] source3/auth/auth.c:332(auth_check_ntlm_password)
  check_ntlm_password:  authentication for user [direction1] -> [direction1] -> [direction1] succeeded
[2026/02/27 06:15:58.902321,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[direction]"
[2026/02/27 06:15:58.902381,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[comptabilite]"
[2026/02/27 06:15:58.902422,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[rh]"
[2026/02/27 06:15:58.902460,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[technique]"
[2026/02/27 06:15:58.902684,  2] source3/param/loadparm.c:2916(lp_do_section)
  Processing section "[commun]"
```

Figure 10: Extrait du fichier `log.192.168.56.1` : chaque entree indique l'horodatage precis, le resultat de l'authentification (`succeeded`), le protocole SMB2/NTLMv2, et les partages charges lors de la session (`direction`, `comptabilite`, `rh`, `technique`, `commun`).

Chaque entree de log contient :

- L'horodatage precis de la connexion (format `[AAAA/MM/JJ HH:MM:SS]`) ;
- L'utilisateur ayant tente la connexion ;
- Le resultat (`succeeded` ou `FAILED with error NT_STATUS_WRONG_PASSWORD`) ;
- Le protocole utilise (SMB2/NTLMv2) ;
- L'adresse IP et le port de la machine cliente ;
- Les partages accedes durant la session.

Utilite forensique des logs

En cas d'incident de securite, ces logs permettent de retracer precisement : qui s'est connecte, quand, depuis quelle machine, sur quel partage, et si la tentative a reussi ou echoue. C'est un element indispensable pour toute investigation post-incident.

7 Securite – Protection contre les attaques

7.1 Desactivation de SMBv1

SMBv1 est desactive via la directive `min protocol = SMB2` dans la section `[global]` de `smb.conf`. Cette mesure est la premiere et la plus fondamentale des protections. Elle a ete validee lors des tests d'attaque depuis Kali (section 7.3).

7.2 Attaque 1 – Enumeration anonyme

7.2.1 Demonstration de la vulnerabilite (avant correction)

Depuis Kali Linux, un attaquant tente de lister les partages *sans s'authentifier* :

```
smbclient -L //192.168.56.20 -N
# -L : List shares (lister les partages)
# -N : No password (connexion anonyme sans mot de passe)
```

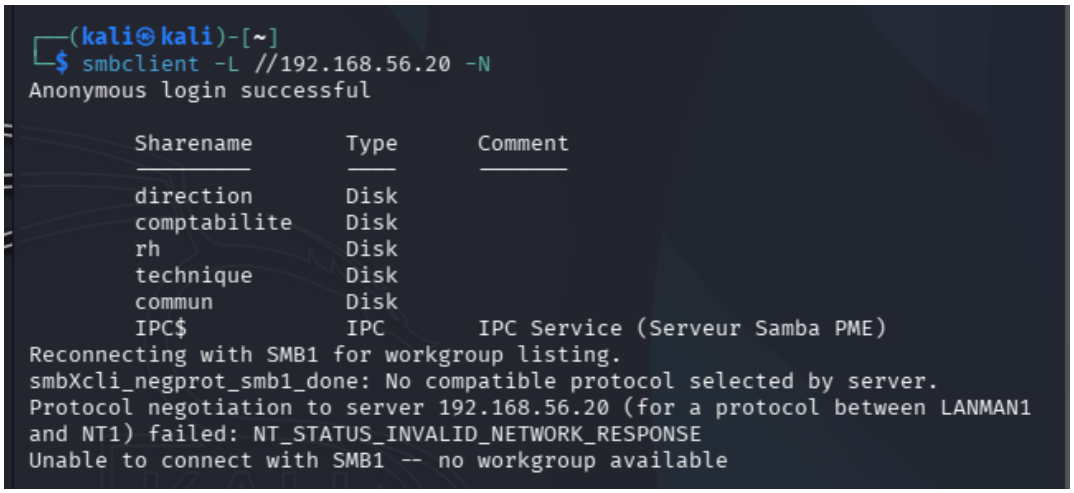

Figure 11: AVANT correction : `Anonymous login successful` – la liste complete des partages (`direction`, `comptabilite`, `rh`, `technique`, `commun`) est visible sans aucun mot de passe. Un attaquant connait deja l'architecture interne de l'entreprise.

Vulnerabilite detectee – Fuite d'information critique

L'acces anonyme permettait a n'importe quelle machine du reseau de decouvrir l'existence et les noms de tous les partages sans la moindre authentification. Dans un contexte reel, un attaquant obtient ainsi une carte de l'organisation interne de l'entreprise, ce qui facilite les attaques ciblees (phishing, ingenierie sociale).

7.2.2 Correction – restriction de l'acces anonyme

Ajout de la directive suivante dans la section `[global]` de `smb.conf` :

```
[global]
   ...
   restrict anonymous = 2
```

Puis redemarrage du service : `sudo systemctl restart smbd`

7.2.3 Validation de la correction

```
┌──(kali㉿kali)-[~]
└─$ smbclient -L //192.168.56.20 -N
Anonymous login successful
tree connect failed: NT_STATUS_ACCESS_DENIED
```

Figure 12: APRES correction : `Anonymous login successful` s'affiche toujours (ouverture de session initiale autorisee) mais la tentative de lister les partages retourne immediatement `tree connect failed: NT_STATUS_ACCESS_DENIED`. L'enumeration est bloquee.

Protection validee – enumeration impossible

Malgre l'ouverture de session anonyme initiale (comportement SMB normal), la tentative de lister les partages est bloquee par `NT_STATUS_ACCESS_DENIED`. Un attaquant ne peut plus decouvrir l'architecture des partages sans s'authentifier avec un compte valide.

7.3 Attaque 2 – Brute force par dictionnaire (Hydra / CrackMapExec)

7.3.1 Tentative avec Hydra

L'outil Hydra tente une attaque par brute force sur le service SMB avec le dictionnaire `rockyou.txt` (14 millions de mots de passe communs) :

```
hydra -l direction1 -P /usr/share/wordlists/rockyou.txt
   192.168.56.20 smb
# -l : login cible (un seul utilisateur)
# -P : fichier de mots de passe (dictionnaire)
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -l direction1 -P /usr/share/wordlists/rockyou.txt 192.168.56.20 smb

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-27 02:
39:33
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:1
4344399), ~14344399 tries per task
[DATA] attacking smb://192.168.56.20:445/
[ERROR] target smb://192.168.56.20:445/ does not support SMBv1
```

Figure 13: Echec d'Hydra : `[ERROR] target does not support SMBv1`. Hydra utilise SMBv1 par defaut pour les attaques SMB ; notre configuration `min protocol = SMB2` le bloque immediatement.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l direction1 -P /usr/share/wordlists/rockyou.txt 192.168.56.20 smb -m smb2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-27 02:44:40
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:14344399), ~14344399 tries per task
[DATA] attacking smb://192.168.56.20:445/smb2
[ERROR] target smb://192.168.56.20:445/ does not support SMBv1
```

Figure 14: Meme en forcant SMB2 avec le flag `-m smb2`, Hydra echoue encore : `[ERROR] target smb://192.168.56.20:445/ does not support SMBv1`. L'outil ne supporte pas correctement le mode SMB2 natif pour le brute force.

7.3.2 Attaque avec CrackMapExec (SMB2/NTLMv2)

CrackMapExec est un outil plus moderne supportant nativement SMB2 :

```
crackmapexec smb 192.168.56.20 -u direction1 \
    -p /usr/share/wordlists/rockyou.txt
```

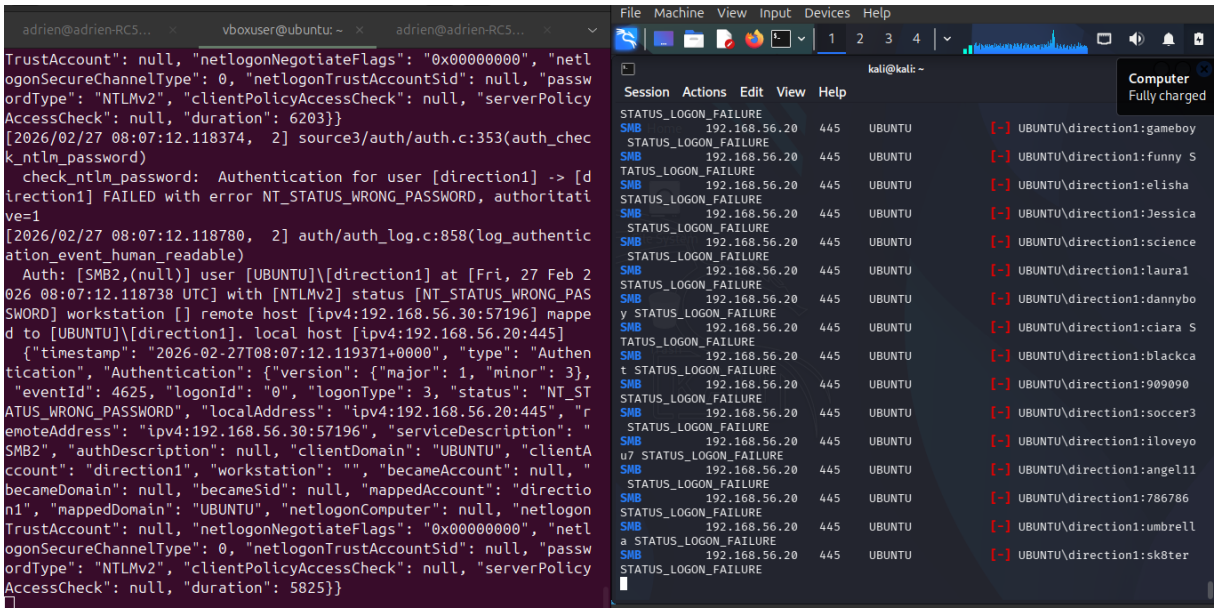

Figure 15: Attaque brute force CrackMapExec en cours : a gauche les logs Samba en temps reel (centaines de `STATUS_LOGON_FAILURE`), a droite CrackMapExec essayant chaque mot de passe du dictionnaire. L'IP attaquante `ipv4:192.168.56.30` est clairement identifiable dans les logs. Aucun mot de passe n'est trouve car il respecte les criteres de robustesse.

Pourquoi l'attaque echoue ?

Le mot de passe `Direction1/+2026` ne figure pas dans `rockyou.txt` car il contient une majuscule, des chiffres et des caracteres speciaux. Les dictionnaires de brute force contiennent des mots courants, des noms propres et des combinaisons simples – pas des mots de passe complexes et uniques. C'est pourquoi la politique de mots de passe robustes est fondamentale.

7.4 Fail2ban – blocage automatique des attaquants

7.4.1 Installation et configuration

```
sudo apt install fail2ban -y
```

Fichier `/etc/fail2ban/jail.local` :

Listing 3: /etc/fail2ban/jail.local

```
[DEFAULT]
bantime  = 600     # Duree du ban : 600 secondes (10 minutes)
findtime = 300     # Fenetre d'observation : 5 minutes
maxretry = 3       # Nombre d'echecs avant ban

[samba]
enabled  = true
port     = 445,139          # Ports SMB/NetBIOS
filter   = samba            # Nom du fichier de filtre
backend  = auto
```

```
logpath  = /var/log/samba/log.*  # Tous les logs Samba
maxretry = 3
bantime  = 600
```

Fichier `/etc/fail2ban/filter.d/samba.conf` :

Listing 4: /etc/fail2ban/filter.d/samba.conf

```
[Definition]
failregex = remote host \[ipv4:<HOST>:\d+\]
ignoreregex =

[Init]
datepattern = ^\[%%Y/%%m/%%d %%H:%%M:%%S
```

- `bantime = 600` : l'IP bannie est bloquee pendant 600 secondes (10 minutes). Apres ce delai, le ban est automatiquement leve. Pour un ban permanent, utiliser `bantime = -1`.
- `findtime = 300` : Fail2ban regarde en arriere sur 5 minutes. Si 3 echecs surviennent dans cette fenetre, le ban est declanche.
- `maxretry = 3` : seuil a 3 echecs avant bannissement. Choix deliberement bas pour stopper rapidement les attaques automatisees.
- `failregex` : expression reguliere qui identifie une ligne de log correspondant a un echec. `<HOST>` est remplace par l'IP capturee.
- `datepattern` : indique a Fail2ban le format de date dans les logs Samba (`[AAAA/MM/JJ HH:MM:SS]`). Les `%%` sont necessaires car le caractere `%` est interprete specialement dans les fichiers ini.
- **Mecanisme** : quand le seuil est atteint, Fail2ban ajoute une regle `nftables` (ou `iptables`) bloquant toutes les connexions depuis l'IP bannie sur les ports 445 et 139.

```
● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
     Active: active (running) since Fri 2026-02-27 08:39:15 UTC; 74ms ago
       Docs: man:fail2ban(1)
   Main PID: 17831 (fail2ban-server)
      Tasks: 1 (limit: 1057)
     Memory: 4.8M (peak: 4.9M)
        CPU: 43ms
     CGroup: /system.slice/fail2ban.service
             └─17831 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Feb 27 08:39:15 ubuntu systemd[1]: Started fail2ban.service - Fail2Ban Service.
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
lines 1-12/12 (END)
```

Figure 16: Verification du statut de Fail2ban avec `sudo systemctl status fail2ban` – service `active (running)` depuis le 27 fevrier 2026. Le PID 17831 indique que le daemon est actif et surveille les logs en temps reel.

7.4.2 Validation – bannissement automatique en action

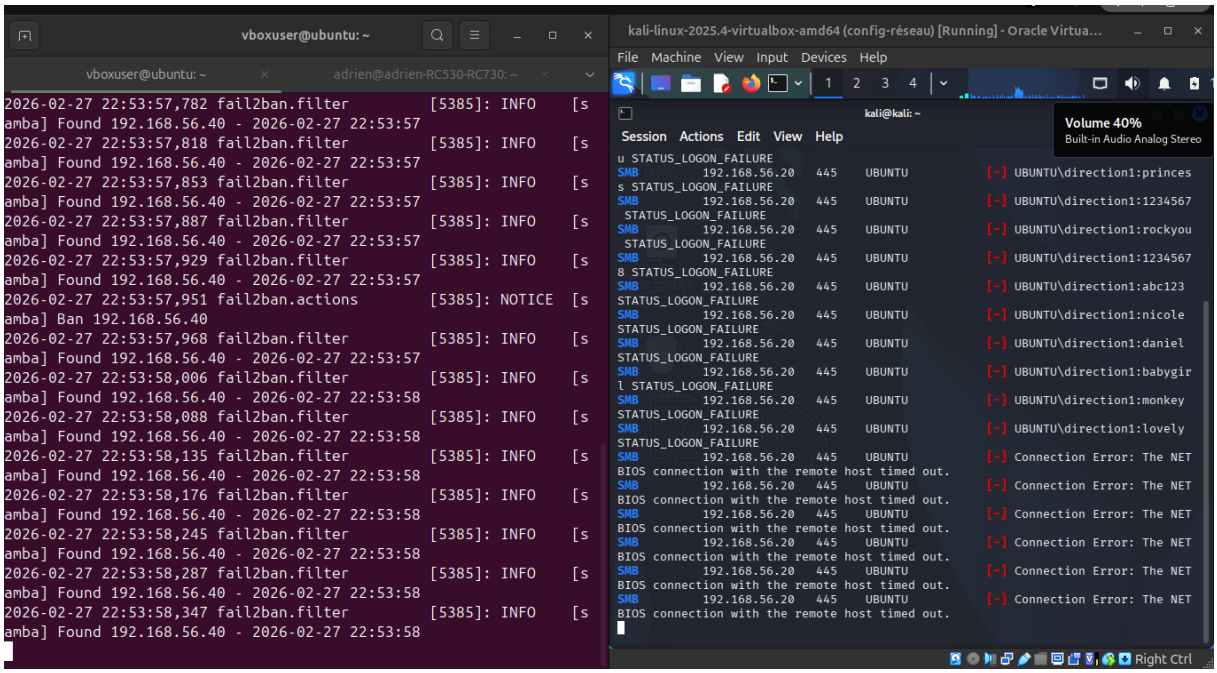

Figure 17: Fail2ban en action : a gauche les logs montrent la progression – `Found 192.168.56.40` a chaque echec, puis `Ban 192.168.56.40` apres le 3eme echec. A droite, Kali recoit `Connection Error: The NETBIOS connection with the remote host timed out` – le serveur ne repond plus du tout.

Fail2ban operationnel – ban automatique confirme

Apres exactement 3 tentatives d'authentification echouees, Fail2ban bannit automatiquement `192.168.56.40` (Kali Linux). Les connexions suivantes de cet attaquant sont immediatement rejetees avec un timeout reseau, sans aucune reponse du serveur – ce qui ralentit aussi les scans de ports.

```
vboxuser@ubuntu:~$ sudo fail2ban-client status samba
[sudo] password for vboxuser:
Status for the jail: samba
|- Filter
|   |- Currently failed: 0
|   |- Total failed:     15
|   `- File list:        /var/log/samba/log.rpcd_winreg /var/log/samba/log.
192.168.56.40.old /var/log/samba/log.192.168.56.1 /var/log/samba/log.samba
-dcerpcd /var/log/samba/log.rpcd_epmapper /var/log/samba/log.kali /var/log
/samba/log.192.168.1.124 /var/log/samba/log.192.168.56.40 /var/log/samba/l
og.adrien-rc530-rc730 /var/log/samba/log.smbd /var/log/samba/log.rpcd_lsad
 /var/log/samba/log.192.168.56.30.old /var/log/samba/log.rpcd_mdssvc /var/
log/samba/log.rpcd_fsrvp /var/log/samba/log.192.168.56.30 /var/log/samba/l
og. /var/log/samba/log.nmbd /var/log/samba/log.rpcd_classic /var/log/samba
/log.rpcd_spoolss
`- Actions
   |- Currently banned: 0
   |- Total banned:     1
   `- Banned IP list:
vboxuser@ubuntu:~$
```

Figure 18: Etat de la jail Samba via `sudo fail2ban-client status samba` : `Total failed: 15` tentatives enregistrees, `Total banned: 1` IP bannie (192.168.56.40). `Currently banned: 0` confirme que le ban de 10 minutes est expire et que l'IP a ete automatiquement liberee. L'historique reste consultable.

8 Sauvegarde automatisee

8.1 Strategie de sauvegarde

La strategie mise en place combine deux types de sauvegarde complementaires :

Type	Frequence	Methode
Complete	Chaque dimanche a 02h00	`tar -czf`
Incrementielle	Lundi – Samedi a 02h00	`rsync -update`

Table 5: Strategie de sauvegarde automatisee

- **Sauvegarde complete (`tar`)** : archive l'integralite de `/srv/samba/` en un fichier `.tar.gz`. Point de restauration fiable mais lent et volumineux – donc une fois par semaine le dimanche.
- **Sauvegarde incrementielle (`rsync`)** : ne copie que les fichiers modifies ou nouveaux depuis la derniere synchronisation. Rapide et economise l'espace disque ; execute tous les jours de la semaine.
- Cette combinaison permet de restaurer a n'importe quel point de la semaine (rsync quotidien) tout en ayant une archive fiable hebdomadaire (tar).

8.2 Script de sauvegarde

Listing 5: /usr/local/bin/backup_samba.sh

```
#!/bin/bash
# Script de sauvegarde automatique Samba PME

SOURCE="/srv/samba/"          # Repertoire source a sauvegarder
BACKUP_DIR="/srv/backup"      # Repertoire de destination
DATE=$(date +%Y-%m-%d)        # Format : 2026-02-27
DAY=$(date +%u)               # Jour de la semaine : 1=Lundi, 7=
   Dimanche

if [ "$DAY" -eq 7 ]; then
    # Dimanche : sauvegarde COMPLETE avec tar
    TYPE="complete"
    tar -czf "$BACKUP_DIR/backup_${TYPE}_${DATE}.tar.gz" "$SOURCE
       "
    echo "[$(date)] Sauvegarde complete effectuee" \
        >> /var/log/samba/backup.log
else
    # Lundi-Samedi : sauvegarde INCREMENTIELLE avec rsync
    TYPE="incrementielle"
    rsync -av --update "$SOURCE" "$BACKUP_DIR/incrementielle/" \
        >> /var/log/samba/backup.log 2>&1
    echo "[$(date)] Sauvegarde incrementielle effectuee" \
        >> /var/log/samba/backup.log
fi
```

- `tar -czf fichier.tar.gz /source/` :
  - `-c` : cree une nouvelle archive (*create*)
  - `-z` : compresse avec `gzip` (reduit la taille d'environ 60%)
  - `-f` : specifie le nom du fichier archive
- `rsync -av -update /source/ /dest/` :
  - `-a` : mode archive (preserve permissions, dates, liens symboliques)
  - `-v` : verbeux (affiche les fichiers traites)
  - `-update` : ne copie que les fichiers *plus recents* que leur correspondant en destination (incrementiel)
- `date +%u` : retourne le jour de la semaine en chiffre (1=lundi ... 7=dimanche). Permet de decider automatiquement le type de sauvegarde.
- `» /var/log/samba/backup.log` : ajoute la sortie au fichier de log (sans ecraser les entrees precedentes).

8.3 Automatisation via cron

```
# Rendre le script executable
sudo chmod +x /usr/local/bin/backup_samba.sh

# Editer la crontab de root
sudo crontab -e

# Ligne a ajouter :
# min heure jour mois jourSemaine commande
0 2 * * * /usr/local/bin/backup_samba.sh
```

```
vboxuser@ubuntu:~$ sudo crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
0 2 * * * /usr/local/bin/backup_samba.sh
```

Figure 19: Crontab root avec la tache planifiee `0 2 * * *` – le script s'executera tous les jours a 02h00. On voit egalement le contenu du journal `backup.log` confirmant une sauvegarde incrementielle reussie.

La syntaxe cron comporte 5 champs : `minute heure jourDuMois mois jourDeLaSemaine`

0	2	*	*	*
minute 0	heure 2h	tous les jours	tous les mois	tous les jours

Le script s'execute donc exactement a **02h00 chaque nuit**, periode de faible activite. Le script lui-meme determine ensuite si c'est un dimanche (sauvegarde

complete) ou un jour de semaine (incrementielle).

8.4 Test de restauration

La procedure de restauration a ete testee en conditions reelles en quatre etapes. Un probleme de permissions a ete identifie et corrige lors de ce test, ce qui constitue un apprentissage important.

Etape 1 – Creation d'un fichier critique :

```
echo "Donnees importantes de la direction" | \
    sudo tee /srv/samba/direction/document_important.txt
```

Etape 2 – Sauvegarde :

```
sudo /usr/local/bin/backup_samba.sh
```

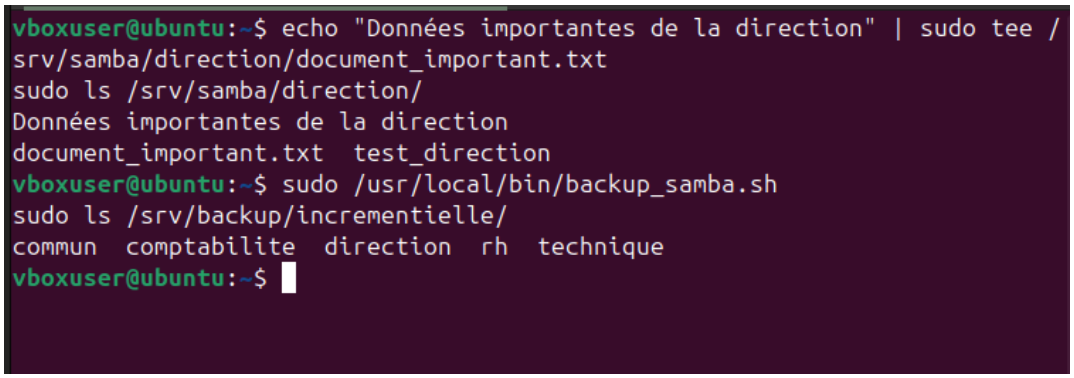

Figure 20: Creation de `document_important.txt` et lancement du script de sauvegarde. Le contenu de `/srv/backup/incrementielle/` confirme que tous les dossiers ont ete sauvegardes.

Etape 3 – Simulation d'une suppression accidentelle :

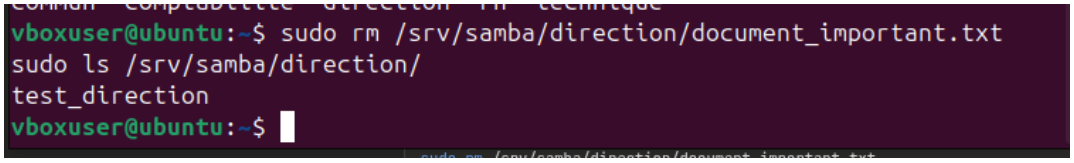

Figure 21: Suppression via `sudo rm` – `document_important.txt` n'apparait plus dans le listing. Le fichier est perdu du point de vue du serveur.

8.4.1 Probleme identifie : pourquoi `sudo cp` est insuffisant

Une premiere tentative de restauration avec la commande naive `sudo cp` a ete effectuee, puis testee depuis les clients Samba :

```
# Mauvaise pratique -- NE PAS utiliser en production
sudo cp /srv/backup/incrementielle/direction/document_important.
    txt \
```

```
/srv/samba/direction/
```

```
vboxuser@ubuntu:~$ sudo ls -la /srv/samba/direction/
total 16
drwxrws--- 3 root       direction 4096 Feb 27 23:09 .
drwxr-xr-x 7 root       root      4096 Feb 26 22:55 ..
-rw-r--r-- 1 root       direction   37 Feb 27 23:09 document_important.txt
drwxrws--- 2 direction1 direction 4096 Feb 27 06:02 test_direction
vboxuser@ubuntu:~$
```

Figure 22: `sudo ls -la /srv/samba/direction/` apres restauration par `sudo cp` : `document_important.txt` appartient a `root:direction` avec les permissions `-rw-r-r-` (644). Le groupe `direction` ne peut que **lire** – le bit `w` du groupe est absent. Comparer avec `test_direction` (cree directement par `direction1`) qui conserve les bonnes permissions avec setgid.

Probleme critique : `sudo cp` detruit les permissions

`sudo cp` sans options cree le fichier restaure avec les permissions par defaut du processus root (umask 022), donnant `-rw-r-r-` (644). Consequences :

- **Lecture** : `direction1` et `direction2` peuvent lire (bit `r` du groupe present) ;
- **Ecriture : IMPOSSIBLE** : le bit `w` du groupe est absent. Toute tentative de modification depuis Samba retourne `NT_STATUS_ACCESS_DENIED` ;
- Le **setgid** du dossier parent (`2770`) ne corrige PAS ce probleme : il s'applique uniquement aux fichiers *crees directement* dans le dossier, jamais aux fichiers *copies* par root.

```
vboxuser@ubuntu: ~        adrien@adrien-RC530-RC730: ~
adrien@adrien-RC530-RC730:~$ smbclient //192.168.56.20/direction -U direction1 -
c \
    "put /tmp/fichier_test.txt document_important.txt"
Password for [WORKGROUP\direction1]:
NT_STATUS_ACCESS_DENIED opening remote file \document_important.txt
adrien@adrien-RC530-RC730:~$ smbclient //192.168.56.20/direction -U direction2 -
c     "put /tmp/fichier_test.txt document_important.txt"
Password for [WORKGROUP\direction2]:
NT_STATUS_ACCESS_DENIED opening remote file \document_important.txt
adrien@adrien-RC530-RC730:~$ smbclient //192.168.56.20/direction -U rh1 -c     "
put /tmp/fichier_test.txt document_important.txt"
Password for [WORKGROUP\rh1]:
tree connect failed: NT_STATUS_ACCESS_DENIED
adrien@adrien-RC530-RC730:~$
```

Figure 23: Preuve du dysfonctionnement : `direction1` **et** `direction2` obtiennent `NT_STATUS_ACCESS_DENIED opening remote file \document_important.txt` en tentant d'ecrire via smbclient. Aucun membre du service Direction ne peut modifier le fichier restaure. Note : `rh1` recoit `tree connect failed` (normal – il n'appartient pas au groupe `direction` et ne peut pas acceder au partage). La restauration par `sudo cp` est donc inutilisable en conditions reelles.

8.4.2 Etape 4 – Restauration correcte avec `rsync -archive`

La solution est d'utiliser `rsync` avec le flag `-archive`, qui **preserve les permissions, le groupe proprietaire et les dates** tels qu'ils etaient au moment de la sauvegarde :

```
# Bonne pratique -- preserve les permissions et le groupe
sudo rsync -av --archive \
    /srv/backup/incrementielle/direction/document_important.txt \
    /srv/samba/direction/
```

```
vboxuser@ubuntu:~$ sudo rsync -av --archive \
    /srv/backup/incrementielle/direction/document_important.txt \
    /srv/samba/direction/
[sudo] password for vboxuser:
sending incremental file list

sent 78 bytes  received 12 bytes  180.00 bytes/sec
total size is 37  speedup is 0.41
vboxuser@ubuntu:~$
```

Figure 24: `rsync -av -archive` en action : `sending incremental file list` confirme l'analyse des differences, puis `document_important.txt` indique le fichier transfere. Les statistiques (`sent 78 bytes, received 12 bytes, total size is 37`) confirment une restauration reussie avec preservation complete des metadonnees.

- `rsync` : outil de synchronisation qui compare source et destination avant de copier, ne transferant que ce qui a change.
- `-archive` (ou `-a`) : mode archive – combine en une seule option :
  - `-r` : recursif (sous-dossiers inclus)
  - `-l` : preserve les liens symboliques
  - `-p` : preserve les **permissions** (chmod) – resout le probleme des 644 vs 660
  - `-t` : preserve les **dates** de modification
  - `-g` : preserve le **groupe proprietaire** – le fichier retrouve son groupe `direction` au lieu de `root`
  - `-o` : preserve le proprietaire (necessite root)
- `-v` : mode verbeux, affiche les fichiers traites.
- **Difference fondamentale avec** `cp` : `cp` sans `-a` ou `-p` cree un nouveau fichier avec les permissions par defaut du processus appelant (root → 644 avec umask 022). `rsync -archive` reproduit le fichier *a l'identique*, permissions et groupe proprietaire inclus.

Restauration correcte validee

Apres `rsync -archive`, le fichier restaure appartient a `root:direction` avec les permissions `-rw-rw--` (660) : les membres du groupe `direction` peuvent lire **et ecrire**. La restauration est complete et operationnelle pour tous les utilisateurs du service.

Pour restaurer un dossier entier :

```
sudo rsync -av -archive /srv/backup/incrementielle/direction/
/srv/samba/direction/
```

9 Difficultes rencontrees et choix techniques

9.1 Difficultes rencontrees

9.1.1 Configuration reseau de la VM

La principale difficulte initiale a ete la configuration du reseau. L'interface Host-Only (`enp0s8`) restait en etat `NO-CARRIER` meme apres la configuration netplan. La cause : l'option *Cable connecte* n'etait pas cochee dans les parametres VirtualBox de l'adaptateur reseau. Une fois cette option activee et l'IP configuree en statique (`192.168.56.20/24`), l'interface est devenue fonctionnelle.

9.1.2 Instabilite de l'IP de Kali

Les IPs assignees manuellement avec `ip addr add` sur Kali ne sont pas persistantes – elles disparaissent a chaque redemarrage ou coupure de courant (qui est survenue plusieurs fois lors du travail). Cela a necessite de reassigner l'IP plusieurs fois pendant les tests, et a oblige a changer l'adresse de `192.168.56.30` a `192.168.56.40` a un moment apres un conflit. La solution perenne aurait ete de configurer la persistance via `/etc/network/interfaces` sur Kali.

9.1.3 Configuration de Fail2ban

Le filtre Fail2ban a necessite plusieurs iterations. Les problemes rencontres :

1. Le caractere `%` dans les patterns de date est interprete differemment par Fail2ban (necessite `%%` dans la section `[Init]`) ;
2. Le filtre initial ne contenait pas de groupe `<HOST>`, rendant impossible l'identification de l'IP a bannir ;
3. Les logs Samba n'incluent pas l'IP dans les lignes d'echec direct – elle se trouve dans les lignes `Auth:` avec le format `remote host [ipv4:X.X.X.X:port]` ;
4. La directive `logpath = /var/log/samba/log.%m` contenait `%m` que Fail2ban interprete comme une variable – remplacement par `log.*` (glob) necessite.

9.1.4 Conflit d'IP avec le reseau Host-Only

Lors de la premiere configuration, l'IP `192.168.56.1` avait ete assignee a la VM alors que c'est l'IP par defaut de l'interface `vboxnet0` du PC hote. Le conflit generait des erreurs de routage. Resolu en assignant `192.168.56.20` a la VM.

9.2 Choix techniques justifies

Choix	Alternative	Justification
Ubuntu Server 24.04	Debian 12	Deja disponible et fonctionnel, moins de configuration initiale, meilleures docs en ligne
Host-Only + Bridge	NAT seul	Bridge pour internet (`apt`), Host-Only pour isoler les tests d'attaque
`rsync` (incrementiel)	`tar` complet quotidien	Plus rapide, ne sauvegarde que les fichiers modifies, economise l'espace
`fail2ban`	`ufw` rate-limit	Fail2ban analyse les logs applicatifs (Samba) et non juste les paquets reseau
`nftables` (via fail2ban)	`iptables`	Standard moderne sur Ubuntu 24, meilleure performance et syntaxe unifiee
Mot de passe complexe	Mot de passe simple	Resiste aux attaques par dictionnaire comme `rockyou.txt`

Table 6: Justification des choix techniques

10 Perspectives d'amelioration

Plusieurs ameliorations pourraient renforcer ce deploiement en conditions de production :

1. **Chiffrement des communications** : activer le chiffrement SMB3 (`smb encrypt = required`) pour chiffrer toutes les donnees en transit. Empeche l'interception meme sur un reseau compromis ;

2. **Integration LDAP/Active Directory** : remplacer la gestion locale des utilisateurs par un annuaire centralise. Indispensable au-dela d'une dizaine d'utilisateurs pour eviter la gestion manuelle ;

3. **Restriction d'acces par IP** : ajouter `hosts allow = 192.168.56.` dans `smb.conf` pour limiter les connexions aux seules machines du reseau interne ;

4. **Sauvegardes distantes** : envoyer les sauvegardes vers un serveur distant ou un stockage cloud (S3, NFS) pour garantir la disponibilite en cas de sinistre physique (incendie, vol) sur le site ;

5. **Persistance des IPs sur Kali** : configurer `/etc/network/interfaces` pour rendre les IPs persistantes entre les redemarrages, evitant de reconfigurer a chaque session de test ;

6. **Bannissement permanent des recidivistes** : passer `bantime = -1` dans Fail2ban avec une whitelist des IPs legit pour les attaques repetees ;

7. **Tests de sauvegarde complete** : bien que la sauvegarde incrementielle ait ete testee et validee, il serait important de valider egalement la restauration depuis une archive `tar` complete (test de disaster recovery).

11 Conclusion

Ce projet a permis de mettre en place un serveur de fichiers Samba complet et securise pour une PME fictive, en partant de zero jusqu'a un deploiement operationnel et teste. L'ensemble des exigences du cahier des charges a ete satisfait :

- Quatre groupes et huit utilisateurs crees avec des espaces dedies et isoles ;
- Permissions strictement differenciees par groupe, avec espace commun partage ;
- SMBv1 desactive, communications en SMB2/SMB3 uniquement ;
- Journalisation complete avec tracabilite de toutes les connexions ;
- Protection contre l'enumeration anonyme (`restrict anonymous = 2`) ;
- Resistance demontree aux attaques par brute force (Hydra echoue, CrackMapExec bloque) ;
- Bannissement automatique des attaquants via Fail2ban (valide en conditions reelles) ;
- Strategie de sauvegarde complete + incrementielle automatisee via cron ;
- Procedure de restauration testee et validee en conditions reelles.

Les difficultes rencontrees – notamment la configuration de Fail2ban (plusieurs iterations pour obtenir le bon filtre regex) et les instabilites reseau liees aux coupures de courant – ont ete autant d'occasions d'approfondir la comprehension des mecanismes sous-jacents. Ce deploiement, realise en environnement virtualise, constitue une base solide transposable a un environnement de production reel.

References

1. Samba Team. *Samba – Opening Windows to a Wider World*. https://www.samba.org/
2. Microsoft. *SMB security enhancements*. https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-security
3. Fail2ban Project. https://www.fail2ban.org/
4. Ubuntu Server Documentation. https://ubuntu.com/server/docs
5. Netplan Reference. https://netplan.io/reference/
6. The Linux Documentation Project. *Linux File Permissions*. https://tldp.org/LDP/intro-linux/html/sect_03_04.html

A Annexe – Recapitulatif des commandes utilisees

Commande	Description
`ip a`	Afficher les interfaces et adresses IP
`sudo netplan apply`	Appliquer la configuration reseau
`sudo apt install samba`	Installer Samba
`samba -version`	Verifier la version de Samba
`sudo systemctl status smbd`	Statut du service Samba
`sudo systemctl restart smbd`	Redemarrer le service Samba
`sudo groupadd <groupe>`	Creer un groupe Linux
`sudo useradd -m -G <groupe> <user>`	Creer un utilisateur dans un groupe
`sudo passwd <user>`	Definir le mot de passe Linux
`sudo smbpasswd -a <user>`	Enregistrer l'utilisateur dans Samba
`sudo chown root:<groupe> <dossier>`	Changer le groupe proprietaire
`sudo chmod 2770 <dossier>`	Permissions setgid + acces total groupe
`sudo chmod 2777 <dossier>`	Permissions setgid + acces total tous
`testparm`	Valider la syntaxe de smb.conf
`smbclient -L //IP -N`	Lister les partages en anonyme (test)
`smbclient -L //IP -U user`	Lister les partages avec authentification
`smbclient //IP/share -U user`	Se connecter a un partage
`sudo tail -f /var/log/samba/log.*`	Surveiller les logs en temps reel
`sudo fail2ban-client status samba`	Statut de la jail Samba dans Fail2ban
`sudo fail2ban-regex <log> <filter>`	Tester un filtre Fail2ban
`sudo /usr/local/bin/backup_samba.sh`	Lancer manuellement la sauvegarde
`sudo crontab -l`	Lister les taches cron root
`sudo crontab -e`	Editer les taches cron root
`tar -czf archive.tar.gz /dossier/`	Creer une archive compressee
`rsync -av -update /src/ /dst/`	Synchronisation incrementielle